

Narrativa explicativa del Kit de Encuesta SQUARE

Cómo convertir confesiones corporativas en inteligencia de país

1. Introducción: por qué preguntar (bien) sobre requisitos

En los informes de ciberseguridad solemos ver dos tipos de gráficos:

- Barras que se disparan con el número de incidentes.
- Pasteles que se reparten vulnerabilidades, ataques y demás delicias.

Lo que rara vez aparece es el “detrás de las cámaras”: cómo se diseñaron los sistemas, qué requisitos de seguridad se escribieron (si alguno), quién decidió qué era “acceptable” y qué no. Ahí es donde SQUARE, esa metodología de ingeniería de requisitos de seguridad nacida en el SEI de Carnegie Mellon, tiene algo que decir.

Este kit de encuesta nace con una intención prosaica pero ambiciosa: convertir la ingeniería de requisitos de seguridad, habitualmente confinada en salas de reunión y documentos técnicos, en un objeto de medición sistemática a escala organizativa y, por qué no, nacional.

2. De SQUARE a la calle

Los nueve pasos de SQUARE –acuerdo sobre objetivos, definición de términos, identificación de activos, elección de técnicas, perfilado de riesgos, elicitación, categorización, priorización y revisión– suenan impecables en un artículo académico. El reto es ver cuánto de esa lógica se materializa en las organizaciones que operan hospitales, redes eléctricas, sistemas tributarios o plataformas digitales.

La encuesta traduce esa coreografía en preguntas concretas:

- ¿Quién está en la sala cuando se hablan de requisitos de seguridad?
- ¿Se escriben requisitos medibles o solo fórmulas piadosas?
- ¿Se revisan y actualizan, o se quedan como un fósil burocrático?
- ¿Se conectan con incidentes, auditorías, normas y presupuestos?

El objetivo no es humillar a nadie, sino aprovechar la virtud paradójica de los cuestionarios: obligan a pensar en voz alta sobre cosas que damos por supuestas.

3. Un espejo para la madurez

El Índice Global de Madurez (IGM) no pretende ser el nuevo PIB de la ciberseguridad, pero sí un termómetro razonable. Al descomponer la realidad en dimensiones (gobernanza, riesgos, requisitos, métricas, capacidades) y asignarles preguntas, invitamos a las organizaciones a verse en un espejo algo más nítido que el tradicional “tenemos ISO 27001, luego estamos seguros”.

La narrativa que emerge no es binaria (cumple/no cumple), sino de trayectorias:

- Organizaciones que han institucionalizado la ingeniería de requisitos de seguridad y la integran en el ciclo de vida de sistemas.

- Otras que dependen de héroes sueltos y plantillas improvisadas.
- Otras que viven de apagar incendios y cruzar los dedos.

El IGM permite, además, comparaciones cuidadosas entre sectores y tamaños, siempre recordando que los números cuentan una historia incompleta si no se acompañan de contexto.

4. España en contexto: de los incidentes a los requisitos

España no parte de cero. INCIBE reporta incidentes, ENISA compara estrategias nacionales, la normativa (NIS2, ENS, sectorial) exige gestiones de riesgo y medidas de seguridad. Sin embargo, el eslabón de la ingeniería de requisitos de seguridad suele quedar diluido entre la política y el control operativo.

El kit SQUARE pretende llenar ese hueco:

- Ofrecer una herramienta común para que hospitales, eléctricas, bancos, administraciones y proveedores puedan describir cómo definen sus requisitos de seguridad.
- Permitir a responsables nacionales y sectoriales observar patrones: qué sectores son más sistemáticos, cuáles dependen de la improvisación, dónde se invierte de verdad en requisitos bien hechos.

Con el tiempo, una serie de encuestas periódicas podría acompañar las métricas de incidentes con métricas de “calidad de diseño”, algo así como la diferencia entre contar incendios y auditar la calidad de los planos de los edificios.

5. ROI, IGM y la economía del lápiz

Hablar de ROI en requisitos de seguridad suele provocar sonrisas escépticas. Buena parte de los beneficios consisten en desastres que no ocurren y titulares que no se escriben. Aun así, ejercitar el músculo de la cuantificación es sano.

La plantilla de Excel propuesta en este kit invita a poner números –aunque sean rangos o estimaciones– a preguntas como:

- ¿Cuántos incidentes evitamos o mitigamos gracias a requisitos bien definidos?
- ¿Cuánto retrabajo ahorramos por detectar problemas de seguridad en las fases tempranas del ciclo de vida?
- ¿Cuánto mejoramos en auditorías y certificaciones cuando los requisitos están claros desde el principio?

El IGM, por su parte, puede ser un indicador adelantado del estado general de la disciplina de requisitos de seguridad en un país. No sustituye a nadie, pero complementa las fotos de incidentes con una radiografía de la arquitectura invisible.

6. Lectores previstos y uso malicioso (en el buen sentido)

Este kit está pensado para varios tipos de actores:

- Responsables de seguridad y tecnología que quieren dejar de hablar solo de firewalls y empezar a hablar de cláusulas, requisitos y compromisos.
- Reguladores y responsables de políticas públicas que buscan instrumentos para ir más allá del cumplimiento mínimo y medir la sustancia de los procesos.
- Investigadores y consultores que necesitan marcos comunes para comparar y aprender de múltiples organizaciones.

Usado con ironía benévola, la encuesta puede convertirse en una conversación incómoda pero productiva dentro de las organizaciones:

- ¿Por qué no hemos definido qué “seguro” significa para este sistema?
- ¿Quién decidió que ciertos requisitos eran opcionales?
- ¿Por qué seguimos sin saber cuánto nos cuesta hacer bien las cosas?

7. Conclusión: de la confesión al cambio

Hacer una encuesta no cambia la realidad por sí mismo; tan solo la ilumina. La gracia está en lo que viene después:

- Trazar planes de mejora realistas.
- Priorizar inversiones en proceso, herramientas y capacidades.
- Repetir la medición y celebrar progresos (o aprender de estancamientos).

En última instancia, SQUARE fue concebido para mejorar la calidad de los requisitos. Este kit simplemente propone un paso previo: preguntarnos con honestidad si esos requisitos existen, cómo son, quién los cuida y qué papel juegan en el tejido digital del país.

Si después de todo esto alguien decide escribir un único requisito nuevo, bien formulado, para un sistema que hasta ahora vivía de la intuición... el ejercicio habrá merecido la pena.